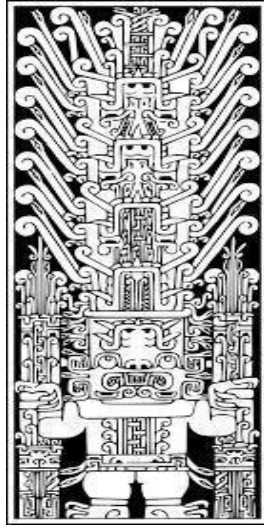


UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



Informe: Seguridad en Profundidad vs Cybersecurity Mesh

AUTOR

Mina Rios Aaron Mark

CURSO

Ciberseguridad

2026

Informe: Seguridad en Profundidad vs Cybersecurity Mesh

1. INTRODUCCIÓN

La transformación digital ha modificado profundamente la forma en que las organizaciones gestionan, almacenan y comparten la información. En las últimas décadas, la adopción de tecnologías como la computación en la nube (Cloud Computing), el Internet de las Cosas (IoT), la virtualización, las aplicaciones basadas en servicios (SaaS), la movilidad empresarial y el trabajo remoto ha permitido incrementar la eficiencia operativa y mejorar la conectividad entre usuarios, dispositivos y sistemas. Sin embargo, esta evolución tecnológica también ha incrementado la complejidad de los entornos informáticos y ha ampliado considerablemente la superficie de ataque que puede ser explotada por actores maliciosos.

A diferencia de las infraestructuras tradicionales, donde la mayoría de los recursos se encontraban protegidos dentro de un único centro de datos corporativo, las organizaciones actuales operan en entornos distribuidos donde la información puede residir simultáneamente en servidores locales, plataformas de nube pública y privada, dispositivos móviles, aplicaciones web y servicios externos. Esta descentralización ha generado nuevos desafíos para la ciberseguridad, ya que los mecanismos tradicionales basados únicamente en la protección del perímetro de red resultan insuficientes frente a amenazas cada vez más sofisticadas y persistentes.

Los ataques cibernéticos han evolucionado tanto en frecuencia como en complejidad. Actualmente, las organizaciones enfrentan amenazas como el ransomware, el phishing avanzado, las amenazas persistentes avanzadas (APT), la explotación de vulnerabilidades de día cero (Zero-Day), el movimiento lateral dentro de las redes corporativas y ataques dirigidos contra infraestructuras críticas. En muchos casos, los atacantes no buscan únicamente comprometer un sistema específico, sino obtener acceso progresivo a diferentes recursos hasta alcanzar información crítica o afectar la continuidad operativa de la organización. Este escenario evidencia la necesidad de adoptar estrategias de seguridad capaces de proteger múltiples activos de manera coordinada y resiliente.

Como respuesta a estos desafíos han surgido diferentes modelos de arquitectura de seguridad que buscan fortalecer la protección de los sistemas de información mediante enfoques complementarios. Entre los más relevantes se encuentran Security in Depth (Defensa en Profundidad) y Cybersecurity Mesh (Malla de Ciberseguridad). Aunque ambos persiguen el objetivo común de reducir los riesgos asociados a las amenazas cibernéticas, cada uno propone una filosofía distinta para proteger los activos digitales de una organización.

Security in Depth constituye una estrategia basada en la implementación de múltiples capas de protección independientes. Su principio fundamental consiste en asumir que ningún mecanismo de seguridad es completamente infalible; por ello, se establecen controles sucesivos que dificultan el avance de un atacante incluso cuando una de las barreras ha sido comprometida. Este modelo integra controles físicos, administrativos y tecnológicos, permitiendo proteger desde la infraestructura de red hasta los usuarios,

aplicaciones y datos críticos. Su enfoque ha sido ampliamente utilizado durante décadas debido a su capacidad para aumentar la resiliencia frente a incidentes de seguridad.

Por otra parte, Cybersecurity Mesh representa una evolución de los modelos tradicionales de protección, adaptándose a los entornos altamente distribuidos que caracterizan a las organizaciones modernas. En lugar de concentrar la seguridad alrededor de un perímetro físico o lógico, este enfoque propone una arquitectura flexible donde cada identidad, dispositivo, aplicación o servicio puede ser protegido mediante políticas centralizadas e interoperables, independientemente de su ubicación. Este modelo adquiere especial importancia en escenarios donde convergen infraestructuras híbridas, múltiples proveedores de servicios en la nube y usuarios que acceden a los recursos corporativos desde diversas ubicaciones geográficas.

La comparación entre ambos modelos resulta especialmente relevante debido a que muchas organizaciones enfrentan el desafío de determinar cuál estrategia se adapta mejor a sus necesidades operativas y de seguridad. Mientras Security in Depth continúa siendo una referencia para la protección mediante capas defensivas, Cybersecurity Mesh introduce un paradigma orientado a la identidad digital, la interoperabilidad y la protección distribuida de activos. Lejos de considerarse enfoques excluyentes, ambos pueden coexistir e integrarse para fortalecer la postura de seguridad de una organización frente al panorama actual de amenazas.

En este contexto, el presente informe tiene como propósito analizar de manera detallada las características, principios, arquitecturas, procesos de implementación, ventajas, limitaciones y escenarios de aplicación de Security in Depth y Cybersecurity Mesh. Asimismo, se realizará una comparación técnica entre ambos modelos con el fin de identificar sus principales diferencias, similitudes y contribuciones dentro de las estrategias modernas de ciberseguridad, proporcionando una visión integral que permita comprender su importancia en la protección de los activos digitales y en el fortalecimiento de la resiliencia organizacional frente a las amenazas cibernéticas actuales.

2. SECURITY IN DEPTH (DEFENSA EN PROFUNDIDAD)

2.1 Definición de Security in Depth

La Seguridad en Profundidad (Security in Depth o Defense in Depth) es una estrategia de ciberseguridad basada en la implementación de múltiples capas de protección que trabajan de forma complementaria para resguardar los activos de una organización. A diferencia de un modelo que depende de un único mecanismo de seguridad, este enfoque asume que ninguna tecnología es completamente infalible, por lo que distribuye diversos controles a lo largo de toda la infraestructura tecnológica.

El principio fundamental consiste en que, si una de las capas de seguridad es vulnerada, las demás continúan ofreciendo protección, dificultando el avance del atacante y reduciendo el impacto de un posible incidente. De esta manera, se incrementa el tiempo y el esfuerzo necesarios para comprometer un sistema, aumentando también las probabilidades de detectar actividades maliciosas antes de que afecten la información o los servicios.

Esta estrategia integra controles físicos, administrativos y tecnológicos, como autenticación, segmentación de redes, monitoreo continuo y recuperación ante incidentes. Además, reconoce que la seguridad absoluta no existe, por lo que busca prevenir, detectar y responder eficazmente ante las amenazas, minimizando sus consecuencias.

Security in Depth constituye la base de numerosos estándares y marcos internacionales de ciberseguridad. Su capacidad para adaptarse a diferentes entornos tecnológicos, desde redes tradicionales hasta infraestructuras híbridas y en la nube, la convierte en uno de los modelos de protección más utilizados por organizaciones públicas y privadas.

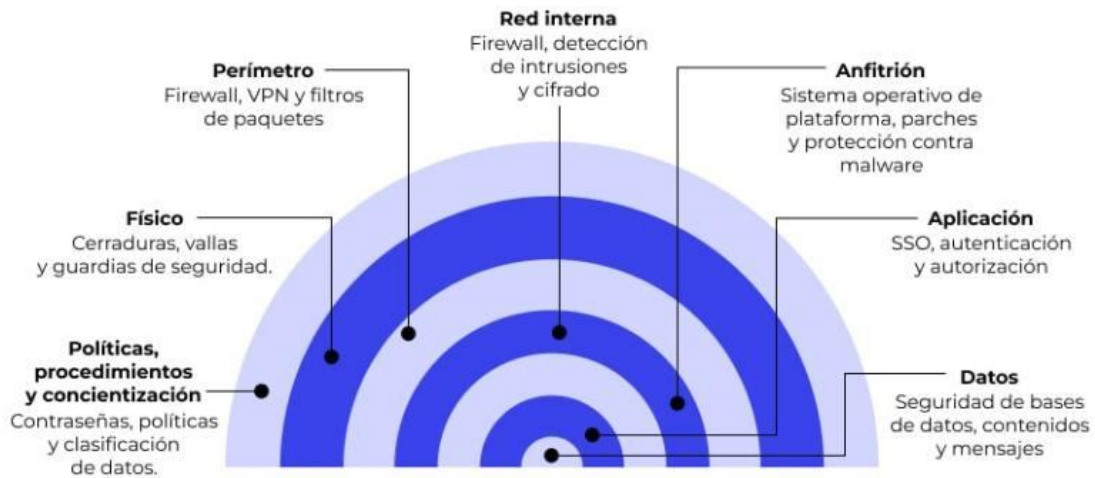
2.2 Origen e Historia de Security in Depth

El concepto de Seguridad en Profundidad tiene su origen en las estrategias militares utilizadas para proteger ciudades y fortalezas mediante varias líneas defensivas. En lugar de confiar únicamente en una muralla, se empleaban fosos, torres y otras barreras que retrasaban el avance del enemigo y facilitaban la respuesta de los defensores. Este principio fue posteriormente adaptado al ámbito de la seguridad informática.

Durante las décadas de 1970 y 1980, la mayoría de los sistemas informáticos funcionaban en redes cerradas, donde la protección física y el control de acceso eran suficientes. Sin embargo, con la expansión de Internet en los años noventa, las organizaciones comenzaron a depender de los firewalls perimetrales, hasta que las nuevas amenazas demostraron que una única barrera de protección era insuficiente.

Como respuesta, se incorporaron múltiples mecanismos de seguridad, entre ellos la autenticación multifactor, la segmentación de redes, los sistemas de detección de intrusiones, el cifrado y el monitoreo continuo. Con el tiempo, la evolución de los ataques consolidó a Security in Depth como un principio esencial para limitar el movimiento de los atacantes y proteger los activos críticos.

Actualmente, este enfoque continúa evolucionando para adaptarse a tecnologías como la computación en la nube, la virtualización y el Internet de las Cosas (IoT). Aunque cambian las infraestructuras tecnológicas, el principio sigue siendo el mismo: combinar diversas capas de seguridad para fortalecer la protección de los sistemas.



3. CYBERSECURITY MESH (MALLA DE SEGURIDAD)

3.1 Definición de Cybersecurity Mesh

La Cybersecurity Mesh o Malla de Ciberseguridad es una arquitectura moderna que protege los activos digitales de manera distribuida, flexible e interoperable. A diferencia de los modelos tradicionales centrados en el perímetro de la red, este enfoque considera que los recursos se encuentran distribuidos entre la nube, dispositivos móviles, aplicaciones y diferentes ubicaciones, por lo que la seguridad debe acompañar a cada activo sin importar dónde se encuentre.

Este modelo surge como respuesta a la transformación digital y al crecimiento del trabajo remoto, la computación en la nube y el Internet de las Cosas. En lugar de concentrar los controles en un único punto de acceso, distribuye la protección entre identidades, dispositivos, aplicaciones y datos, todos administrados mediante políticas de seguridad unificadas.

Uno de sus pilares es la verificación continua de la identidad digital, donde cada solicitud de acceso es evaluada según el usuario, el dispositivo y el nivel de riesgo. Además, promueve la interoperabilidad entre diferentes soluciones de seguridad, facilitando una respuesta coordinada frente a incidentes y fortaleciendo la implementación del modelo Zero Trust.

Gracias a estas características, Cybersecurity Mesh representa una evolución importante en la ciberseguridad moderna, ya que ofrece un modelo adaptable a infraestructuras distribuidas y capaz de enfrentar los desafíos derivados de la transformación digital y las amenazas actuales.

3.2 Origen e Historia de Cybersecurity Mesh

El concepto de Cybersecurity Mesh surgió debido a la transformación de las infraestructuras tecnológicas en la última década. Las organizaciones dejaron de

concentrar sus recursos en un único centro de datos y comenzaron a utilizar servicios en la nube, aplicaciones SaaS, dispositivos móviles y entornos híbridos, haciendo insuficiente el modelo tradicional basado únicamente en la protección del perímetro.

Ante esta realidad, la empresa de investigación Gartner propuso Cybersecurity Mesh como una arquitectura capaz de proteger los recursos sin importar su ubicación física. Su objetivo fue integrar identidades, aplicaciones, dispositivos y datos mediante políticas comunes de autenticación, autorización y monitoreo continuo.

La necesidad de este modelo aumentó con el crecimiento de los entornos multinube y, especialmente, durante la pandemia de COVID-19, cuando el trabajo remoto incrementó la exposición a amenazas cibernéticas. Esto impulsó la adopción de enfoques centrados en la identidad del usuario y en la evaluación constante del riesgo, principios compartidos con Zero Trust.

En la actualidad, Cybersecurity Mesh continúa evolucionando mediante tecnologías como la inteligencia artificial, la automatización y las plataformas XDR. Su flexibilidad e interoperabilidad la convierten en una de las arquitecturas más relevantes para proteger organizaciones con infraestructuras distribuidas y dinámicas.



4. COMPARACION TECNICA ENTRE SECURITY IN DEPTH Y CYBERSECURITY MESH

La evolución constante de las amenazas informáticas ha impulsado el desarrollo de nuevas estrategias para proteger los activos digitales de las organizaciones. Entre las arquitecturas más relevantes se encuentran Security in Depth (Defensa en Profundidad) y Cybersecurity Mesh (Malla de Ciberseguridad). Aunque ambas tienen como propósito fortalecer la postura de seguridad frente a los riesgos cibernéticos, difieren en su filosofía de protección, en la forma de administrar los controles de seguridad y en los entornos tecnológicos para los cuales fueron concebidas.

Security in Depth nació en una época donde la mayor parte de los recursos tecnológicos se encontraba dentro de un centro de datos corporativo, protegido por un perímetro claramente definido. Su estrategia consiste en implementar múltiples capas de defensa para evitar que el compromiso de un único mecanismo permita el acceso directo a la información crítica. Por el contrario, Cybersecurity Mesh fue diseñado para responder a las necesidades de las organizaciones modernas, caracterizadas por infraestructuras distribuidas, múltiples proveedores de nube, aplicaciones descentralizadas y usuarios que acceden desde cualquier ubicación. En este modelo, la seguridad deja de depender del perímetro y se centra en proteger cada activo mediante políticas unificadas y mecanismos de autenticación continua.

Característica	Security in Depth	Cybersecurity Mesh
Modelo	Protección mediante capas superpuestas de seguridad (firewall → WAF → IDS → control de acceso)	Seguridad distribuida basada en la identidad digital del usuario y el contexto de acceso
Enfoque	Infraestructura y perímetro de red. Protege los sistemas como si fueran un castillo con murallas y fosos	Usuario, dispositivo y contexto. No existe un perímetro fijo; la identidad es el nuevo perímetro
Protección	Mediante filtros internos en capas: si el atacante supera una capa, la siguiente lo detiene	Validación y verificación antes de permitir cualquier acceso, sin importar la ubicación
Punto de control	Firewall (red), WAF (aplicación), IDS/IPS (detección), control de acceso (usuarios)	Identidad digital, MFA, políticas de acceso contextual, certificados y tokens
Acceso al sistema	Un atacante puede llegar a capas internas si supera los controles externos (menor protección en profundidad)	Se bloquea el acceso antes de entrar al sistema; cada solicitud se verifica independientemente
Arquitectura	Centralizada. Los controles se aplican en puntos específicos de la infraestructura	Distribuida. Los controles se aplican en cada nodo, dispositivo y servicio de forma independiente
Adaptación cloud	Media. Diseñado originalmente para infraestructuras on-premise con perímetros definidos	Alta. Nativo para entornos cloud, multicloud e híbridos donde no existe perímetro físico
Trabajo remoto	Limitado. Requiere VPN u otros mecanismos adicionales para usuarios fuera del perímetro	Nativo. Cada usuario se autentica independientemente sin necesidad de VPN corporativa
Escalabilidad	Media. Escalar implica replicar toda la infraestructura de seguridad	Alta. Las políticas se aplican de forma distribuida, fácilmente escalables en la nube

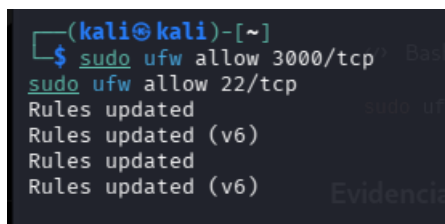
Este comando instala el paquete UFW en el sistema operativo Ubuntu utilizando el gestor de paquetes APT (Advanced Package Tool). A continuación se explica cada elemento del comando:

- `sudo`: Ejecuta el comando con privilegios de superusuario (root). Es necesario porque instalar software en el sistema requiere permisos administrativos.
- `apt install`: Invoca al gestor de paquetes APT en su modo de instalación. APT se encarga de descargar el paquete desde los repositorios oficiales de Ubuntu, resolver dependencias y llevar a cabo la instalación.
- `ufw`: Es el nombre del paquete que se desea instalar. UFW (Uncomplicated Firewall) es la interfaz simplificada para el firewall iptables del kernel Linux.
- `-y`: Este flag (bandera) confirma automáticamente todas las preguntas que APT realiza durante el proceso de instalación (como '¿Desea continuar? [S/n]'), evitando que el administrador deba escribir 'S' manualmente.

Permitir únicamente servicios necesarios

```
sudo ufw allow 3000/tcp
```

```
sudo ufw allow 22/tcp
```



```
(kali㉿kali)-[~]  
$ sudo ufw allow 3000/tcp  
Rules updated  
Rules updated (v6)  
$ sudo ufw allow 22/tcp  
Rules updated  
Rules updated (v6)
```

Este comando crea una regla en el firewall para permitir conexiones entrantes al puerto 3000 usando el protocolo TCP.

- `allow`: Indica que se está creando una regla de PERMISO. El tráfico que coincida con esta regla será aceptado por el firewall.
- `3000`: Es el número de puerto que se está abriendo. El puerto 3000 es el puerto por defecto en el que corre OWASP Juice Shop, la aplicación web vulnerable que se utiliza en este laboratorio de seguridad.
- `/tcp`: Especifica que la regla aplica únicamente al protocolo TCP (Transmission Control Protocol). TCP es el protocolo orientado a conexión utilizado por HTTP y HTTPS, lo que significa que las peticiones web al Juice Shop usarán este protocolo.

Bloquear el resto:

```
sudo ufw default deny incoming
```

```
sudo ufw enable
```

```
(kali@kali)-[~]
$ sudo ufw default deny incoming
sudo ufw enable
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
Firewall is active and enabled on system startup
```

Este comando abre el puerto 22 para permitir conexiones SSH (Secure Shell) al servidor.

- **allow 22/tcp:** Permite el acceso al puerto 22 por TCP, que es el puerto estándar del protocolo SSH según el RFC 4253.
- **SSH (Secure Shell):** Protocolo de red que permite el acceso remoto seguro a sistemas Linux/Unix. Cifra toda la comunicación entre el cliente y el servidor.
- **Importancia crítica:** Esta regla DEBE ejecutarse ANTES de activar el firewall. Si se habilita UFW con política de denegación por defecto sin haber abierto el puerto 22, el administrador quedaría bloqueado sin poder ingresar al servidor remotamente. Esto se conoce como 'lock-out' y es uno de los errores más comunes al configurar firewalls.

Verificar:

```
sudo ufw status verbose
```

```
(kali㉿kali)-[~]
└─$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip

Evidencia

To Action From
--
3000/tcp ALLOW IN Anywhere
22/tcp ALLOW IN Anywhere
3000/tcp (v6) ALLOW IN Anywhere (v6)
22/tcp (v6) ALLOW IN Anywhere (v6)

↓

(kali㉿kali)-[~]
└─$ sudo ufw status
```

Este comando muestra el estado completo y detallado de la configuración del firewall.

- **status:** Consulta el estado actual de UFW (activo o inactivo) y lista las reglas configuradas.
- **verbose:** Agrega información adicional a la salida, incluyendo: el estado general (active/inactive), la política por defecto para tráfico entrante, saliente y enrutado, y la lista completa de reglas con su dirección, puerto, protocolo y acción.

Evidencia:

```
sudo ufw status
```

```
(kali@kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip

To Action From
--
3000/tcp ALLOW IN Anywhere
22/tcp ALLOW IN Anywhere
3000/tcp (v6) ALLOW IN Anywhere (v6)
22/tcp (v6) ALLOW IN Anywhere (v6)

(kali@kali)-[~]
$ sudo ufw status
Status: active

To Action From
--
3000/tcp ALLOW Anywhere
22/tcp ALLOW Anywhere
3000/tcp (v6) ALLOW Anywhere (v6)
22/tcp (v6) ALLOW Anywhere (v6)
```

Se muestra de forma clara y concisa qué puertos están abiertos y el estado del firewall.

Segunda Capa – WAF:

¿Qué es un WAF y para qué sirve?

Un Web Application Firewall (WAF) es un tipo especial de firewall que opera en la Capa 7 (Aplicación) del modelo OSI. A diferencia de UFW que trabaja a nivel de red (puertos e IPs), el WAF inspecciona el contenido de las peticiones HTTP/HTTPS, detectando y bloqueando ataques específicos a aplicaciones web como: inyecciones SQL (SQLi), Cross-Site Scripting (XSS), inclusión de archivos remotos (RFI), y ataques incluidos en las OWASP Top 10.

En este laboratorio se utiliza Nginx como servidor proxy inverso y ModSecurity como motor WAF. Esta combinación representa la segunda capa de defensa del modelo Security in Depth.

Instalar nginx:

```
sudo apt install nginx -y
```

```
kali@kali: ~  
Session Actions Edit View Help  
-(kali@kali)-[~]  
$ sudo apt install nginx -y  
The following packages were automatically installed and are no longer required:  
libavc1394-0 libpostal1 libxmlsec1-1 python3-pluginbase  
libicu76 libstdl2-classic libxmlsec1-openssl python3-pysnmp4  
libio-pty-perl libsimdutf31 openjdk-21-jre  
libipc-run-perl libteamctl0 openjdk-21-jre-headless  
libpostal-data libunibreak6 postgresql-common-dev  
Use 'sudo apt autoremove' to remove them.  
  
Upgrading:  
nginx nginx-common  
  
Summary:  
Upgrading: 2, Installing: 0, Removing: 0, Not Upgrading: 709  
Download size: 756 kB  
Space needed: 2,048 B / 57.6 GB available  
  
Get:1 http://kali.download/kali kali-rolling/main amd64 nginx amd64 1.30.1-4 [647 kB]  
Get:2 http://kali.download/kali kali-rolling/main amd64 nginx-common all 1.30.1-4 [109 kB]  
Fetched 756 kB in 1s (1,108 kB/s)  
Preconfiguring packages ...  
(Reading database... 435330 files and directories currently installed.)  
Preparing to unpack ./nginx_1.30.1-4_amd64.deb...  
Unpacking nginx (1.30.1-4) over (1.30.0-2)...  
Preparing to unpack ./nginx-common_1.30.1-4_all.deb...  
Unpacking nginx-common (1.30.1-4) over (1.30.0-2)...  
Setting up nginx-common (1.30.1-4)...  
Setting up nginx (1.30.1-4)...  
Processing triggers for man-db (2.13.1-1)...  
Processing triggers for kali-menu (2026.2.5)...  
Processing triggers for ufw (0.36.2-9)...  
Scanning processes ...  
Scanning linux images ...
```

Instala Nginx, uno de los servidores web y proxies inversos más utilizados en el mundo. En este laboratorio, Nginx no se usa como servidor web directo sino como PROXY INVERSO: se interpone entre el usuario y Juice Shop, inspeccionando todo el tráfico antes de reenviarlo.

- Proxy Inverso: Nginx recibe las peticiones del cliente en el puerto 80 (HTTP estándar), las inspecciona con ModSecurity, y si son legítimas, las reenvía a Juice Shop en el puerto 3000.
- Beneficio: El usuario final solo ve el puerto 80 (estándar). Juice Shop queda 'oculto' detrás de Nginx, protegido por el WAF.
- Nginx como intermediario: Si ModSecurity detecta un ataque (como un payload de SQLi), Nginx devuelve un error HTTP 403 Forbidden y NUNCA reenvía la petición maliciosa a Juice Shop.

Instalar ModSecurity:

```
sudo apt install libnginx-mod-http-modsecurity -y
```

```
kali@kali: ~  
Session Actions Edit View Help  
No VM guests are running outdated hypervisor (qemu) binaries on this host.  
ChatGPT  
(kali@kali)~  
$ sudo apt install libnginx-mod-http-modsecurity -y  
The following packages were automatically installed and are no longer required:  
libavc1394-0 libpostl1 libxmlsec1-1 python3-pluginbase  
libc76 libssl2-classic libxmlsec1-openssl python3-pysnmp4  
libio-pty-perl libsimdutf31 openjdk-21-jre  
libipc-run-perl libteamctl0 openjdk-21-jre-headless  
libpostal-data libunibreak6 postgresql-common-dev  
Use 'sudo apt autoremove' to remove them.  
  
Installing:  
libnginx-mod-http-modsecurity  
  
Installing dependencies:  
libfuzzy2 libmodsecurity-dev libmodsecurity3t64 libnginx-mod-http-ndk modsecurity-crs  
  
Suggested packages:  
lua geoip-database-contrib python libapache2-mod-security2  
  
Summary:  
Upgrading: 0, Installing: 6, Removing: 0, Not Upgrading: 709  
Download size: 1,573 kB  
Space needed: 10.1 MB / 57.6 GB available  
  
Get:1 http://http.kali.org/kali kali-rolling/main amd64 libfuzzy2 amd64 2.14.1+git20180629.57fcfff-3+b3 [18.2 kB]  
Get:2 http://kali.download/kali kali-rolling/main amd64 libmodsecurity3t64 amd64 3.0.15-1 [624 kB]  
Get:6 http://elmirror.cl/kali kali-rolling/main amd64 modsecurity-crs all 3.3.9-1 [164 kB]  
Get:3 http://kali.download/kali kali-rolling/main amd64 libmodsecurity-dev amd64 3.0.15-1 [731 kB]  
Get:4 http://http.kali.org/kali kali-rolling/main amd64 libnginx-mod-http-ndk amd64 1:0.3.4-4+b5 [10.1 kB]  
Get:5 http://kali.download/kali kali-rolling/main amd64 libnginx-mod-http-modsecurity amd64 1.0.4-1 [26.2 kB]  
Fetched 1,573 kB in 1s (1,161 kB/s)
```

Instala el módulo ModSecurity para Nginx. ModSecurity es el WAF de código abierto más utilizado en el mundo y es el motor que realiza el análisis del tráfico HTTP.

- **libnginx-mod-http-modsecurity:** Es el paquete oficial que integra ModSecurity directamente en Nginx como módulo dinámico.
- **¿Qué hace ModSecurity?:** Analiza cada petición HTTP entrante (headers, body, parámetros URL) comparándola contra un conjunto de reglas de seguridad. Si una petición coincide con un patrón de ataque conocido, ModSecurity puede: registrar el evento (modo detección), o bloquear la petición (modo prevención).
- **OWASP CRS (Core Rule Set):** Conjunto de reglas estándar para ModSecurity que detecta los ataques más comunes del OWASP Top 10. Estas reglas se actualizan continuamente por la comunidad.

Configurar Reverse Proxy

Editar:

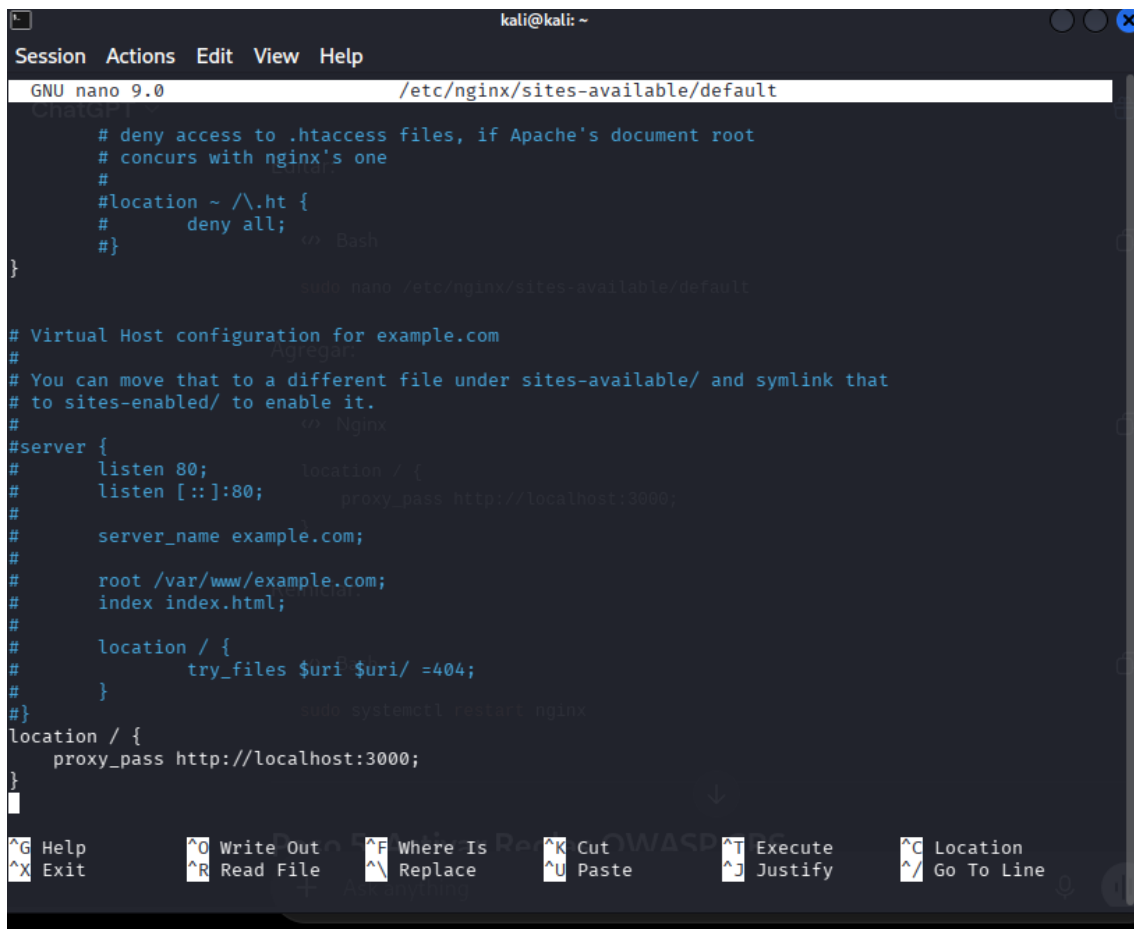
```
sudo nano /etc/nginx/sites-available/default
```

Agregar:

```
location / {  
    proxy_pass http://localhost:3000;  
}
```

Reiniciar:

sudo systemctl restart nginx



The screenshot shows a terminal window with the nano text editor open at the file `/etc/nginx/sites-available/default`. The editor's status bar at the top indicates 'GNU nano 9.0'. The configuration file contains several commented-out sections and one active server block. The active server block is configured to listen on port 80, serve the `example.com` virtual host, and proxy requests to `http://localhost:3000`. The bottom of the terminal shows the nano editor's command shortcuts.

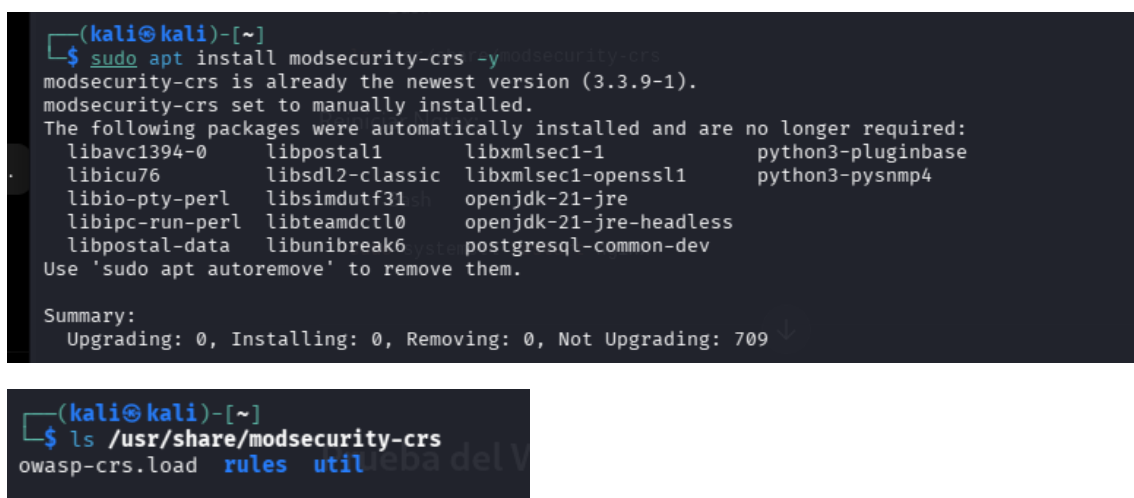
```
Session  Actions  Edit  View  Help
GNU nano 9.0 /etc/nginx/sites-available/default
# deny access to .htaccess files, if Apache's document root
# concurs with nginx's one
#
#location ~ /\.ht {
#    deny all;
#}

# Virtual Host configuration for example.com
#
# You can move that to a different file under sites-available/ and symlink that
# to sites-enabled/ to enable it.
#
#server {
#    listen 80;
#    listen [::]:80;
#
#    server_name example.com;
#
#    root /var/www/example.com;
#    index index.html;
#
#    location / {
#        try_files $uri $uri/ =404;
#    }
#}
location / {
    proxy_pass http://localhost:3000;
}

^G Help      ^O Write Out ^F Where Is  ^K Cut       ^T Execute
^X Exit      ^R Read File ^_ Replace   ^U Paste     ^J Justify
^_ Location  ^_ Go To Line
```

Activar reglas OWASP CRS

Instalar:



The first screenshot shows the command `sudo apt install modsecurity-crs -y` being executed. The output indicates that the package is already installed and lists several packages that are no longer required. The second screenshot shows the command `ls /usr/share/modsecurity-crs` being executed, which lists the files `owasp-crs.load`, `rules`, and `util`.

```
(kali@kali)-[~]
$ sudo apt install modsecurity-crs -y
modsecurity-crs is already the newest version (3.3.9-1).
modsecurity-crs set to manually installed.
The following packages were automatically installed and are no longer required:
libavc1394-0 libpostal1 libxmlsec1-1 python3-pluginbase
libicu76 libstdl2-classic libxmlsec1-openssl python3-pysnmp4
libio-pty-perl libsimdtf31 openjdk-21-jre
libipc-run-perl libteamdctl0 openjdk-21-jre-headless
libpostal-data libunibreak6 postgresql-common-dev
Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 709

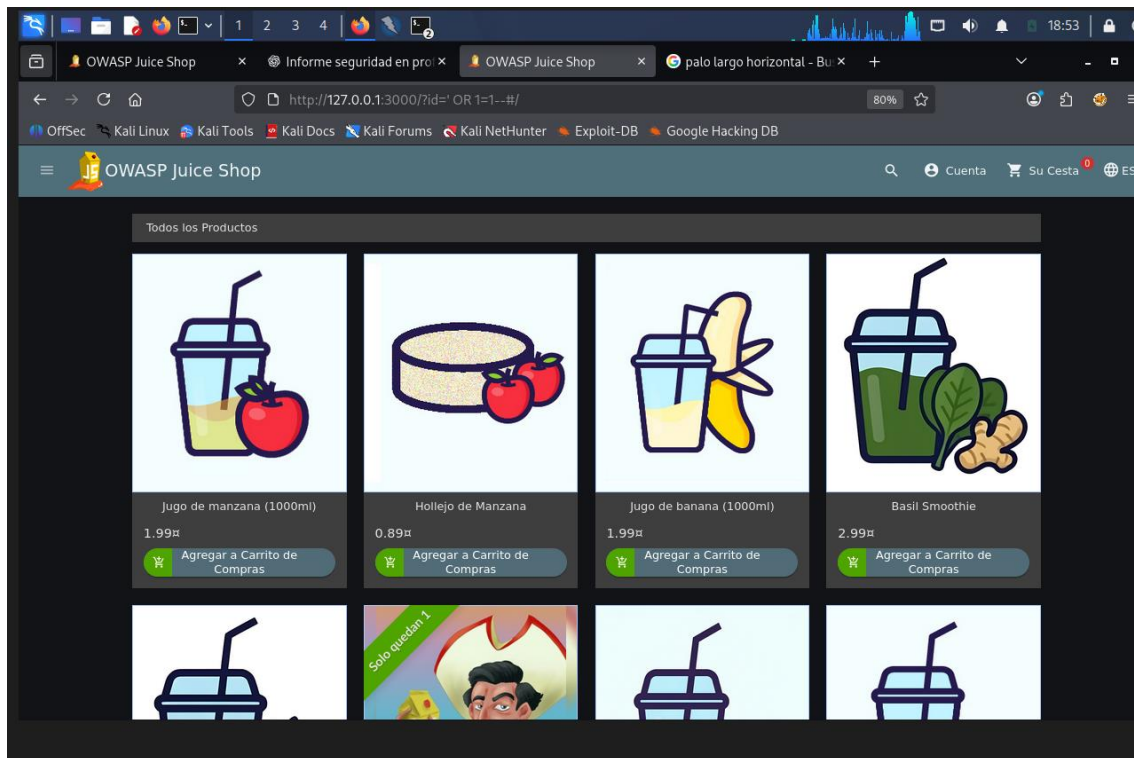
(kali@kali)-[~]
$ ls /usr/share/modsecurity-crs
owasp-crs.load  rules  util
```

Descripción detallada:

Este bloque de configuración dentro de Nginx es el corazón del proxy inverso:

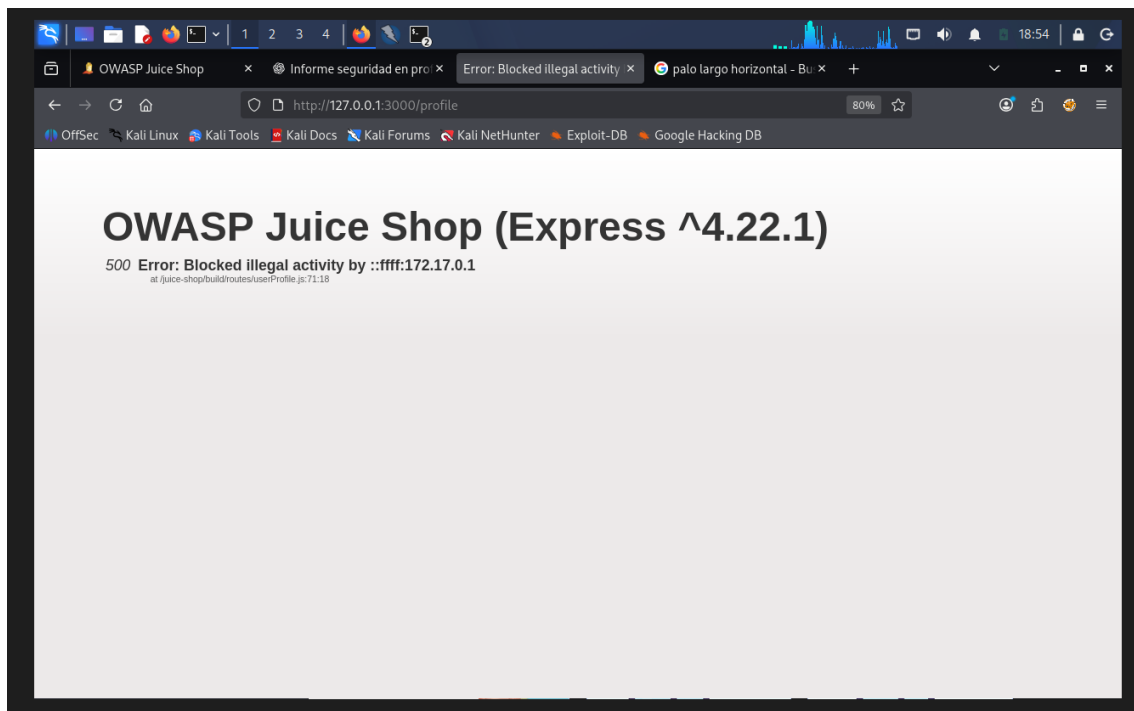
- location /: Aplica esta configuración a TODAS las rutas de la URL (el '/' significa raíz, es decir, cualquier petición).
- proxy_pass http://localhost:3000: Indica a Nginx que reenvíe las peticiones al servidor local (localhost) en el puerto 3000, donde está corriendo Juice Shop.
- Flujo del tráfico con el WAF activo: Usuario → [Internet] → Puerto 80 (Nginx+ModSecurity) → [Si es legítimo] → Puerto 3000 (Juice Shop). Si ModSecurity detecta un ataque, la petición nunca llega al puerto 3000.

Vizualizar el bloqueo



Este bloque de configuración dentro de Nginx es el corazón del proxy inverso:

- location /: Aplica esta configuración a TODAS las rutas de la URL (el '/' significa raíz, es decir, cualquier petición).
- proxy_pass http://localhost:3000: Indica a Nginx que reenvíe las peticiones al servidor local (localhost) en el puerto 3000, donde está corriendo Juice Shop.
- Flujo del tráfico con el WAF activo: Usuario → [Internet] → Puerto 80 (Nginx+ModSecurity) → [Si es legítimo] → Puerto 3000 (Juice Shop). Si ModSecurity detecta un ataque, la petición nunca llega al puerto 3000.



Conclusiones

- El análisis realizado permitió identificar que Security in Depth y Cybersecurity Mesh son dos arquitecturas de ciberseguridad con enfoques diferentes, pero complementarios. Mientras la primera se basa en la implementación de múltiples capas de protección para reducir el impacto de un ataque, la segunda centra la seguridad en la identidad, los dispositivos y el acceso a los recursos distribuidos, respondiendo a las necesidades de los entornos tecnológicos modernos.
- Se concluye que Security in Depth continúa siendo una estrategia efectiva para proteger infraestructuras tradicionales mediante controles como firewalls, WAF, segmentación de redes y monitoreo continuo. La implementación práctica realizada con UFW y ModSecurity demostró cómo varias capas de seguridad pueden actuar de manera coordinada para prevenir y mitigar ataques dirigidos a aplicaciones web.
- Cybersecurity Mesh representa una evolución de la ciberseguridad al adaptarse a entornos híbridos, multinube y de trabajo remoto. Su integración con principios como Zero Trust, autenticación multifactor y gestión centralizada de identidades permite ofrecer una protección más flexible y adecuada para organizaciones que operan con recursos distribuidos.
- Se concluye que ninguna de las dos arquitecturas debe considerarse como un reemplazo de la otra. La combinación de las capas de defensa propuestas por Security in Depth con la flexibilidad e interoperabilidad de Cybersecurity Mesh permite fortalecer la postura de seguridad de las organizaciones frente a las amenazas cibernéticas actuales y futuras

Recomendaciones

- Implementar un enfoque de Seguridad en Profundidad que combine controles físicos, administrativos y tecnológicos, evitando depender de un único

mecanismo de protección y reduciendo el riesgo de que una vulnerabilidad comprometa toda la infraestructura.

- Adoptar progresivamente arquitecturas de Cybersecurity Mesh en organizaciones que utilicen servicios en la nube, aplicaciones SaaS, dispositivos móviles o entornos híbridos, incorporando principios como Zero Trust, autenticación multifactor (MFA) y gestión centralizada de identidades.
- Mantener actualizados los mecanismos de seguridad, incluyendo firewalls, WAF, sistemas de detección de intrusiones y reglas de protección, además de realizar monitoreo continuo y auditorías periódicas para identificar vulnerabilidades antes de que puedan ser explotadas.
- Capacitar de forma permanente al personal en buenas prácticas de ciberseguridad, ya que el factor humano continúa siendo una de las principales causas de incidentes. La combinación de tecnologías de protección con una adecuada concientización de los usuarios contribuye significativamente a fortalecer la seguridad de la organización.